

Case study: Sigstore — transparency log + signing infrastructure footprint

CASE-2026-003 - status OPEN - priority MEDIUM

CASE NUMBER

CASE-2026-003

TEAM

-

REPORT GENERATED

2026-05-21 11:58:24 UTC

CUSTODIAN

Admin

CASE OPENED

2026-05-21 00:24:56 UTC

GENERATED BY

Admin

Forensic case opened from investigation Investigation: sigstore.dev. Target: sigstore.dev

CHAIN-OF-CUSTODY ATTESTATION

VERIFIED

CHAIN LENGTH
3 entries

HEAD HASH (SHA-256)
c02bb4d0ad063f0fed42a6949965f574922911ef8e3cba0056b337fa56f9117e

GENESIS HASH
00

REPORT DIGEST (SHA-256)
902ca9cc5377aad82b71392cb5b51296fde2244eb3fa3a87a5fa603151f1e0d1

Evidence inventory

5 items - 0 verified or sealed - 0 backed by real file bytes on disk.

NAME	TYPE	STATUS	SIZE	SHA-256	OBJECT KEY	ADDED
Finding cmpeqml5 - Domain ownership linked to Google-managed project (sigstore)	document application/x-osint-finding	COLLECTED	-	d7be370866d7... SHA-256	(metadata-only)	2026-05-21 00:24:56 UTC
Finding cmpeqml5 - Sigstore blog and documentation hosted on GitHub Pages via Fastly CDN	document application/x-osint-finding	COLLECTED	-	e2bfca6081ec... SHA-256	(metadata-only)	2026-05-21 00:24:56 UTC
Finding cmpeqml5 - Rekor transparency log service is publicly reachable	document application/x-osint-finding	COLLECTED	-	e6c305974b90... SHA-256	(metadata-only)	2026-05-21 00:24:56 UTC
Finding cmpeqml4 - Sigstore.dev primary infrastructure hosted on Google Cloud	document application/x-osint-finding	COLLECTED	-	e09ce216193e... SHA-256	(metadata-only)	2026-05-21 00:24:56 UTC
Finding cmpeqml4 - identity pipeline returned unstructured output	document application/x-osint-finding	COLLECTED	-	c5e48b326f82... SHA-256	(metadata-only)	2026-05-21 00:24:56 UTC

Findings

5 findings across 1 investigations.

Domain ownership linked to Google-managed project (sigstore)

INFRASTRUCTURE PROBABLE PRIORITY: LOW - Investigation: sigstore.dev

TXT records include "google-site-verification" tokens and "OSSRH-67470" indicating verification with Google services and Maven Central. Combined with Google Cloud DNS and hosting, this points to the domain being owned and managed by the Sigstore open-source project under Google's umbrella.

```
{
  "technique": "KAC",
  "inputs": [
    {
      "sourceId": "whois_dns_output",
      "summary": "TXT records: google-site-verification=..., OSSRH-67470, gradle-verification token.",
      "credibility": 4,
      "recencyDays": 0
    }
  ],
  "reasoning": "Verification tokens tied to Google services and Maven Central imply control by an entity that can manage Google Cloud resources and publish artifacts, consistent with the Sigstore project's known governance.",
  "outputCandidates": [
    {
      "label": "Google-affiliated ownership",
      "weight": 0.12,
      "disconfirmingEvidence": "WHOIS record showing a different registrant unrelated to Google or Sigstore."
    }
  ],
  "selected": 0
}
```

Sigstore blog and documentation hosted on GitHub Pages via Fastly CDN

INFRASTRUCTURE PROBABLE PRIORITY: MEDIUM - Investigation: sigstore.dev

Subdomains blog.sigstore.dev and search.sigstore.dev return HTTP 200 with server header "GitHub.com" and technology list including Fastly, GitHub Pages, Varnish. This indicates static content is served from GitHub infrastructure, typical for open-source project sites.

```
{
  "technique": "QoIC",
  "inputs": [
    {
      "sourceId": "httpx_probe_output",
      "summary": "blog.sigstore.dev: title \"Sigstore Blog - Sigstore Blog\", tech Fastly, GitHub Pages, Varnish. search.sigstore.dev: title \"Rekor Search\", same tech stack.",
      "credibility": 5,
      "recencyDays": 0
    }
  ],
  "reasoning": "Consistent server and CDN fingerprints across both subdomains strongly suggest they are served from GitHub Pages with Fastly as front-end CDN.",
  "outputCandidates": [
    {
      "label": "GitHub Pages hosting",
      "weight": 0.08,
      "disconfirmingEvidence": "Server header indicating a different hosting provider (e.g., AWS, Azure) for these subdomains."
    }
  ],
  "selected": 0
}
```

Rekor transparency log service is publicly reachable

INFRASTRUCTURE CONFIRMED PRIORITY: CRITICAL - Investigation: sigstore.dev

The subdomain rekor.sigstore.dev resolves and returns HTTP 200 with a page titled "sigstore". Technology stack includes Google Cloud CDN and HTTP/3, confirming the Rekor transparency log is operational and exposed to the internet.

```
{
  "technique": "Indicators",
  "inputs": [
    {
      "sourceId": "httpx_probe_output",
      "summary": "rekor.sigstore.dev responded 200, title \"sigstore\", tech includes Google Cloud CDN, HTTP/3.",
      "credibility": 5,
      "recencyDays": 0
    }
  ],
  "reasoning": "A live HTTP 200 response with expected service branding confirms the Rekor component is active. No redirects or errors observed.",
  "outputCandidates": [
    {
      "label": "Rekor service operational",
      "weight": 0.02,
      "disconfirmingEvidence": "HTTP 4xx/5xx response, service down page, or DNS NXDOMAIN for rekor.sigstore.dev."
    }
  ],
  "selected": 0
}
```

Sigstore.dev primary infrastructure hosted on Google Cloud

INFRASTRUCTURE CONFIRMED PRIORITY: HIGH - Investigation: sigstore.dev

DNS resolution for sigstore.dev returns Google Cloud DNS name servers and A records pointing to Google Cloud IP ranges. HTTP probing of multiple subdomains (rekor, status, tuf-repo-cdn, v1.fulcio) shows server headers and technology fingerprints (Google Cloud, Google Cloud CDN, Google Cloud Storage, HTTP/3). This indicates the core services are provisioned on Google Cloud Platform.

```
{
  "technique": "QoIC",
  "inputs": [
    {
      "sourceId": "whois_dns_output",
      "summary": "DNS NS records point to ns-cloud-a*.googledomains.com; A records 99.83.231.61, 75.2.60.5 belong to Google Cloud.",
      "credibility": 5,
      "recencyDays": 0
    },
    {
      "sourceId": "httpx_probe_output",
      "summary": "Subdomains return tech fingerprints: Google Cloud, Google Cloud CDN, Google Cloud Storage, HTTP/3.",
      "credibility": 5,
      "recencyDays": 0
    }
  ],
  "reasoning": "Both authoritative DNS configuration and live service fingerprints independently identify Google Cloud as the hosting environment, satisfying QoIC criteria for high-confidence evidence.",
  "outputCandidates": [
    {
      "label": "Google Cloud hosting",
      "weight": 0.05,
      "disconfirmingEvidence": "Presence of non-Google IPs or server headers indicating another provider for core services."
    }
  ],
  "selected": 0
}
```

identity pipeline returned unstructured output

IDENTITY UNVERIFIED PRIORITY: LOW - Investigation: sigstore.dev

(no model output - adapter "openrouter" model "openai/gpt-oss-120b:free" produced no content)

```
{"error": "extractJson: no JSON opener in ", "raw_excerpt": ""}
```

Audit log (last 3 entries)

Forward-linked SHA-256 chain. Verifiable offline using the recipe in docs/07-SECURITY.md.

TIMESTAMP	ACTION	ENTITY	ACTOR	HASH
2026-05-21 00:24:56 UTC	bridge_investigation_to_case	Case cmper13so001jabex5n3xywp2	system	7379dcb6667a...
2026-05-21 00:24:56 UTC	findings_promoted_to_evidence	Case cmper13so001jabex5n3xywp2	system	2bb5215cc944...
2026-05-21 00:25:18 UTC	generate_case_report	Case cmper13so001jabex5n3xywp2	Admin	c02bb4d0ad06...